

02

BOOK 02 / 08

보안의 기본 용어

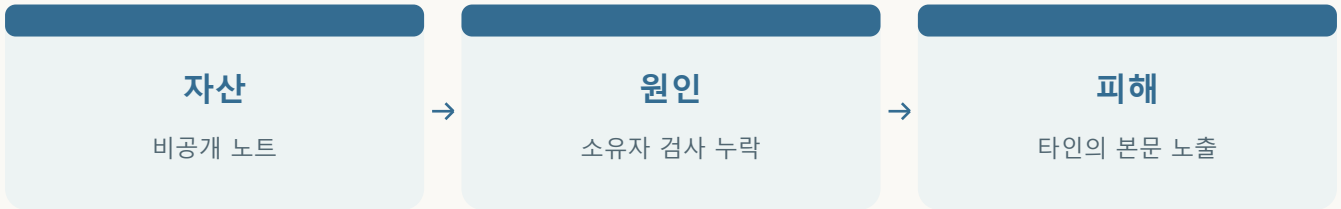
무엇을 어떤 피해로부터 보호하는가?

개념 이해 / 사례 읽기 / 확인 문제 약 15분

비공개 학습 노트 서비스를 따라 배우는 보안의 기본

이 책을 읽는 방법

원인·조건·피해를 구체적인 말로 설명합니다.



읽기 순서

학습 목표와 선수 지식	3
시작 상황: '위험하다'를 구체적으로 말하기	3
개념 설명	3
사례를 한 문장으로 정리하기	4
개발·검수 시 확인사항	4
핵심 요약	4
확인 문제	5
정답과 해설	6
다음 학습과 출처	6

사례를 먼저 읽고, 개념과 코드의 차이를 확인한 뒤 문제를 풀어 보세요. 정답과 해설은 문제 다음 페이지에서 시작합니다.

공통 사례 / 비공개 학습 노트

민서(사용자 101)의 노트는 10번, 준호(202)의 노트는 20번입니다. 모든 노트는 비공개이며, 로그인한 소유자만 조회·수정할 수 있습니다. 제목은 1~80자의 일반 텍스트입니다.

비밀번호·세션 토큰은 로그에 남기지 않고, 권한을 확인할 수 없으면 본문을 보내지 않습니다. 이 가상 서비스의 예제는 학습용 축약본이며 실제 서비스의 계정·데이터·구현과 무관합니다.

학습 목표와 선수 지식

1단원의 서비스 정책을 알고 있다고 가정합니다. 학습 후에는 자산·위협·보안약점·취약점·위험을 사례에 연결하고, 기밀성·무결성·가용성 관점에서 피해를 설명할 수 있습니다.

시작 상황: '위험하다'를 구체적으로 말하기

'노트 서비스가 위험하다'는 말만으로는 무엇을 고쳐야 하는지 알기 어렵습니다. '다른 사용자가 번호를 바꾸어 비공개 노트를 읽을 수 있다'고 말하면 보호 대상과 문제가 드러납니다.

개념 설명

용어	이 과정에서 사용하는 의미	노트 서비스의 예
자산	보호할 가치가 있는 정보·기능·자원	비공개 본문, 계정, 서비스 이용 가능 상태
위협	자산에 피해를 줄 수 있는 사건이나 행위의 가능성	타인의 노트 열람, 계정 탈취
보안약점	보안 문제의 원인이 될 수 있는 설계·구현상의 부족함	노트 소유자 검사 누락
취약점	특정 시스템에서 보안 침해로 이어질 수 있는 구체적인 결함	운영 중인 조회 기능에서 다른 사람의 본문이 반환되는 결함
공격	보호 조건을 깨뜨리기 위한 실제 시도	다른 사람의 노트 번호로 요청을 보내기
위험	발생 가능성과 영향을 함께 고려한 판단	많은 비공개 노트가 쉽게 노출될 가능성과 피해

문서마다 '약점'과 '취약점'을 혼용하기도 합니다. 이 과정에서는 학습 분류로서의 약점과 특정 구현의 결함을 구분하는 데 초점을 둡니다. 모든 위험을 단순한 숫자 곱셈으로 정확히 계산할 수 있는 것은 아닙니다.

보호 목표를 설명할 때는 다음 세 관점이 유용합니다.

관점	질문	침해 사례
기밀성	허용된 사람만 정보를 볼 수 있는가?	준호의 비공개 노트를 민서가 읽음
무결성	허가되지 않은 변경을 막는가?	민서가 준호의 학습 기록을 수정함
가용성	필요한 시점에 서비스를 사용할 수 있는가?	자원 고갈로 정상 사용자의 조회가 계속 실패함

하나의 결함이 여러 목표를 해칠 수 있습니다. 다른 사람의 노트를 삭제할 수 있다면 데이터 무결성과 이용 가능성 모두에 영향을 줍니다. 피해 대상에는 정보뿐 아니라 사용자 시간과 서비스 신뢰도도 포함될 수 있습니다.

사례를 한 문장으로 정리하기

‘노트 소유자 검사 누락이라는 약점으로 인해, 인증된 다른 사용자가 번호를 변경해 비공개 본문을 열람할 수 있다. 그 결과 노트의 기밀성이 훼손될 수 있다.’

이 표현은 ‘해킹 위험’이라는 말보다 원인·조건·피해가 구체적입니다. 피해 규모는 공개된 노트의 수, 내용의 민감도, 접근 가능한 사용자 범위 등에 따라 달라집니다.

개발·검수 시 확인사항

문제를 기록할 때는 ‘보호 대상 → 발생 조건 → 허가되지 않은 행동 → 영향’을 남깁니다. 공격자가 이용할 수 있는 조건이 실제로 존재하는지 확인하고, 확인하지 않은 피해까지 발생했다고 단정하지 않습니다.

핵심 요약

- 자산은 보호 대상, 약점은 문제의 원인, 위험은 가능성과 영향을 함께 보는 판단입니다.
- 기밀성·무결성·가용성은 서로 다른 보호 목표입니다.
- 취약점 이름만 말하지 말고 발생 조건과 영향을 함께 설명합니다.

확인 문제

1. 다른 사용자가 내 노트를 읽기만 했습니다. 내용이 바뀌지 않았으므로 피해가 없다는 설명은 맞을까요?

2. 노트 내용을 바꿀 수 있는 결함을 발견했지만 실제 이용자가 공격했는지는 확인하지 못했습니다. '사용자 노트가 변조되었다'고 보고해도 될까요?

정답과 해설

1. 아닙니다. 무결성 침해가 없어도 기밀성 침해가 발생할 수 있습니다.
2. 안 됩니다. '변조할 수 있는 결함을 확인했다'와 '실제 변조가 발생했다'를 구분해야 합니다.

다음 학습과 출처

다음 단원에서는 약점이 생기는 위치를 찾기 위해 데이터 흐름을 살펴봅니다. 분류 용어는 Python 시큐어코딩 가이드의 보안약점 체계와 연결하며, 위 표는 입문자를 위한 작업 정의입니다.

나의 한 문장

이 강의에서 배운 내용을 동료에게 설명한다면 어떻게 말할까요?
